

Exp No:1 Governance and Regulation

Aim

To study and understand the fundamental concepts of cybersecurity governance, compliance, laws, regulations, policies, and risk management using the Governance and Regulation exercise on TryHackMe.

Procedure

1. Log in to the TryHackMe platform and open the Governance and Regulation exercise.
2. Read the given tasks and study the concepts of governance, regulations, policies, and compliance.
3. Answer the questions provided in each task.
4. Verify the answers and complete the exercise.
5. Record the completion status and key concepts learned.

Tasks

Task1:

Answer the questions below

I am ready to start the room.

No answer needed

✓ Correct Answer

Task2:

Answer the questions below

A rule or law enforced by a governing body to ensure compliance and protect against harm is called?

Regulation

✓ Correct Answer

5

Health Insurance Portability and Accountability Act (HIPAA) targets which domain for data protection?

Healthcare

✓ Correct Answer

Task3:

The step that involves monitoring compliance and adjust the document based on feedback and changes in the threat landscape or regulatory environment is called?

Review and update

✓ Correct Answer



A set of specific steps for undertaking a particular task or process is called?

Procedure

✓ Correct Answer

Task 4:

What is the component in the GRC framework involved in identifying, assessing, and prioritising risks to the organisation?

Risk Management

✓ Correct Answer



Is it important to monitor and measure the performance of a developed policy? (yea/nay)

yea

✓ Correct Answer

Task 5:

What is the maximum fine for Tier 1 users as per GDPR (in terms of percentage)?

4

✓ Correct Answer

In terms of PCI DSS, what does CHD stand for?

cardholder data

✓ Correct Answer



Task 6:

Per NIST 800-53, in which control category does the media protection lie?

Physical

✓ Correct Answer



Per NIST 800-53, in which control category does the incident response lie?

Administrative

✓ Correct Answer

Which phase (name) of NIST 800-53 compliance best practices results in correlating identified assets and permissions?

Map

✓ Correct Answer

Task 7:

Which ISO/IEC 27001 component involves selecting and implementing controls to reduce the identified risks to an acceptable level?

Risk treatment

✓ Correct Answer

In SOC 2 generic controls, which control shows that the system remains available?

Availability

✓ Correct Answer

Task 8:

Click the **View Site** button at the top of the task to launch the static site in split view. What is the flag after completing the exercise?

THM{SECURE_1001}

✓ Correct Answer

Result

The Governance and Regulation exercise was successfully completed, and the concepts of cybersecurity governance, regulations, compliance, and risk management were understood.